

Security Scan Report

Target: http://127.0.0.1:5001

Scan Date: April 14, 2026 at 17:27 UTC

Scan ID: 68df8b1d-fb96-4b9c-a6ef-3382e31e4c69

0 CRITICAL

4 HIGH

13 MEDIUM

4 LOW

Executive Summary

Security scan of 'http://127.0.0.1:5001' identified 26 raw findings, reduced to 21 unique issues after deduplication. ■ 4 HIGH-severity issue(s) should be prioritized for remediation within the next 48 hours. 13 MEDIUM-priority issue(s) should be addressed in the current development sprint. 4 LOW-priority issue(s) have been logged for backlog tracking.

Scan Statistics

Metric	Value
Total Raw Findings	26
After Deduplication	21
Critical Findings	0
High Findings	4
Medium Findings	13
Low Findings	4
Scan Duration	61.9s

Detailed Findings

[HIGH] #1: Sql Injection in sql-lab?id=1:0

Risk Score	0.7350
Affected Location	http://127.0.0.1:5001/sql-lab?id=1:0
Vulnerability Type	SQL_INJECTION
CWE ID	CWE-89
Detected By	url-scanner

Explanation
SQL Injection occurs when user-controlled input is directly concatenated into SQL queries, allowing an attacker to manipulate the query logic. This can lead to unauthorized data access, modification, or deletion of database records.

Code or HTTP Excerpt

```
1 | Request: GET http://127.0.0.1:5001/sql-lab?id=%27
2 | Payload: id='
3 | Response excerpt: sqlite3.OperationalError: unrecognized token: "'"
4 | query=SELECT * FROM users WHERE id = '
```

Business Impact
An attacker could read, modify, or delete all data in the database, potentially exposing customer records and sensitive business data.

Fix Recommendation
Rule-based recommendation: Use parameterized queries instead of string concatenation. In Python, use placeholder syntax: `cursor.execute('SELECT * FROM users WHERE id = ?', (user_id,))`. For ORMs, use the built-in query builder instead of raw SQL.

LLM recommendation: Use parameterized queries instead of string concatenation. In Python, use placeholder syntax: `cursor.execute('SELECT * FROM users WHERE id = ?', (user_id,))`. For ORMs, use the built-in query builder instead of raw SQL.

[HIGH] #2: Ssrf in sql-lab?id=1:0

Risk Score	0.5922
Affected Location	http://127.0.0.1:5001/sql-lab?id=1:0
Vulnerability Type	SSRF
CWE ID	CWE-918
Detected By	url-scanner

Explanation
Server-Side Request Forgery (SSRF) occurs when an application makes HTTP requests to URLs controlled by user input, allowing attackers to access internal services and infrastructure.

Code or HTTP Excerpt

```
1 | Request: GET http://127.0.0.1:5001/sql-lab?id=http%3A%2F%2F127.0.0.1%3A80%2F
```

```
2 | Payload: http://127.0.0.1:80/
3 | Status: 500
4 | Response excerpt: sqlite3.OperationalError: unrecognized token: ":"
5 | query=SELECT * FROM users WHERE id = http://127.0.0.1:80/
```

Business Impact

An attacker could access internal services, cloud metadata endpoints, or other systems not intended to be publicly accessible.

Fix Recommendation

Rule-based recommendation: Whitelist allowed domains and IP addresses for outbound requests. Block requests to internal IP ranges (169.254.x.x, 10.x.x.x, 172.16-31.x.x, 192.168.x.x). Validate and sanitize all URLs before making requests.

LLM recommendation: Whitelist allowed domains and IP addresses for outbound requests. Block requests to internal IP ranges (169.254.x.x, 10.x.x.x, 172.16-31.x.x, 192.168.x.x). Validate and sanitize all URLs before making requests.

[HIGH] #3: Cors Misconfiguration in 127.0.0.1:5001:0

Risk Score	0.5841
Affected Location	http://127.0.0.1:5001:0
Vulnerability Type	CORS_MISCONFIGURATION
CWE ID	CWE-942
Detected By	url-scanner

Explanation

The server's Cross-Origin Resource Sharing (CORS) policy is overly permissive, potentially allowing unauthorized websites to make requests and read responses on behalf of users.

Code or HTTP Excerpt

```
1 | Access-Control-Allow-Origin: *
2 | Access-Control-Allow-Credentials: true
```

Business Impact

A malicious website could make authenticated API requests on behalf of your users and read the responses, potentially accessing sensitive data.

Fix Recommendation

Rule-based recommendation: Restrict Access-Control-Allow-Origin to specific trusted domains instead of using wildcard (*). Never combine wildcard origins with Access-Control-Allow-Credentials: true.

LLM recommendation: Restrict Access-Control-Allow-Origin to specific trusted domains instead of using wildcard (*). Never combine wildcard origins with Access-Control-Allow-Credentials: true.

[HIGH] #4: Insecure Transport in 127.0.0.1:5001:0

Risk Score	0.5700
Affected Location	http://127.0.0.1:5001:0

Vulnerability Type	INSECURE_TRANSPORT
CWE ID	CWE-319
Detected By	url-scanner

Explanation
The site is served over unencrypted HTTP. All data transmitted between the user and the server — including passwords, session tokens, and personal data — can be intercepted by attackers.

Business Impact
User credentials, personal data, and session tokens can be intercepted by anyone on the same network, leading to account takeover and data theft.

Fix Recommendation
Rule-based recommendation: Enable HTTPS with a valid TLS certificate (e.g. via Let's Encrypt). Redirect all HTTP traffic to HTTPS. Add the Strict-Transport-Security header to prevent future HTTP connections.

LLM recommendation: Enable HTTPS with a valid TLS certificate (e.g. via Let's Encrypt). Redirect all HTTP traffic to HTTPS. Add the Strict-Transport-Security header to prevent future HTTP connections.

[MEDIUM] #5: Xss in health:0

Risk Score	0.5141
Affected Location	http://127.0.0.1:5001/fetch?url=http://127.0.0.1:5001/health:0
Vulnerability Type	XSS
CWE ID	CWE-79
Detected By	url-scanner

Explanation
Cross-Site Scripting (XSS) occurs when untrusted data is included in web page output without proper encoding, allowing attackers to inject malicious scripts that execute in users' browsers.

Code or HTTP Excerpt

```
1 | Request: GET http://127.0.0.1:5001/fetch?url=%22%3E%3Cimg+src%3Dx+onerror%3Dalert%281%29%3E
2 | Payload: url=""><img src=x onerror=alert(1)>
3 | Reflection found in response body
```

Business Impact
An attacker could steal user session tokens, redirect users to malicious sites, or perform actions on behalf of authenticated users.

Fix Recommendation
Rule-based recommendation: Apply context-aware output encoding to all user-controlled data before rendering in HTML. Use your framework's built-in escaping (e.g., Jinja2 auto-escaping, React JSX). For manual escaping, reference OWASP ESAPI.

LLM recommendation: Apply context-aware output encoding to all user-controlled data before rendering in HTML. Use your framework's built-in escaping (e.g., Jinja2 auto-escaping, React JSX). For manual escaping, reference OWASP ESAPI.

[MEDIUM] #6: Xss in sql-lab?id=1:0

Risk Score	0.5141
Affected Location	http://127.0.0.1:5001/sql-lab?id=1:0
Vulnerability Type	XSS
CWE ID	CWE-79
Detected By	url-scanner

Explanation

Cross-Site Scripting (XSS) occurs when untrusted data is included in web page output without proper encoding, allowing attackers to inject malicious scripts that execute in users' browsers.

Code or HTTP Excerpt

```
1 | Request: GET http://127.0.0.1:5001/sql-lab?id=%3Cscript%3Ealert%281%29%3C%2Fscript%3E
2 | Payload: id=<script>alert(1)</script>
3 | Reflection found in response body
```

Business Impact

An attacker could steal user session tokens, redirect users to malicious sites, or perform actions on behalf of authenticated users.

Fix Recommendation

Rule-based recommendation: Apply context-aware output encoding to all user-controlled data before rendering in HTML. Use your framework's built-in escaping (e.g., Jinja2 auto-escaping, React JSX). For manual escaping, reference OWASP ESAPI.

LLM recommendation: Apply context-aware output encoding to all user-controlled data before rendering in HTML. Use your framework's built-in escaping (e.g., Jinja2 auto-escaping, React JSX). For manual escaping, reference OWASP ESAPI.

[MEDIUM] #7: Xss in reflect?name=:0

Risk Score	0.5141
Affected Location	http://127.0.0.1:5001/reflect?name=:0
Vulnerability Type	XSS
CWE ID	CWE-79
Detected By	url-scanner

Explanation

Cross-Site Scripting (XSS) occurs when untrusted data is included in web page output without proper encoding, allowing attackers to inject malicious scripts that execute in users' browsers.

Code or HTTP Excerpt

```
1 | Request: GET http://127.0.0.1:5001/reflect?name=%3Cscript%3Ealert%281%29%3C%2Fscript%3E
2 | Payload: name=<script>alert(1)</script>
3 | Reflection found in response body
```

Business Impact

An attacker could steal user session tokens, redirect users to malicious sites, or perform actions on behalf of authenticated users.

Fix Recommendation

Rule-based recommendation: Apply context-aware output encoding to all user-controlled data before rendering in HTML. Use your framework's built-in escaping (e.g., Jinja2 auto-escaping, React JSX). For manual escaping, reference OWASP ESAPI.

LLM recommendation: Apply context-aware output encoding to all user-controlled data before rendering in HTML. Use your framework's built-in escaping (e.g., Jinja2 auto-escaping, React JSX). For manual escaping, reference OWASP ESAPI.

[MEDIUM] #8: Xss in download?file=ACC-100001.txt:0

Risk Score	0.5141
Affected Location	http://127.0.0.1:5001/download?file=ACC-100001.txt:0
Vulnerability Type	XSS
CWE ID	CWE-79
Detected By	url-scanner

Explanation

Cross-Site Scripting (XSS) occurs when untrusted data is included in web page output without proper encoding, allowing attackers to inject malicious scripts that execute in users' browsers.

Code or HTTP Excerpt

```
1 | Request: GET http://127.0.0.1:5001/download?file=%22%3E%3Cimg+src%3Dx+onerror%3Dalert%281%29%3E
2 | Payload: file=""><img src=x onerror=alert(1)>
3 | Reflection found in response body
```

Business Impact

An attacker could steal user session tokens, redirect users to malicious sites, or perform actions on behalf of authenticated users.

Fix Recommendation

Rule-based recommendation: Apply context-aware output encoding to all user-controlled data before rendering in HTML. Use your framework's built-in escaping (e.g., Jinja2 auto-escaping, React JSX). For manual escaping, reference OWASP ESAPI.

LLM recommendation: Apply context-aware output encoding to all user-controlled data before rendering in HTML. Use your framework's built-in escaping (e.g., Jinja2 auto-escaping, React JSX). For manual escaping, reference OWASP ESAPI.

[MEDIUM] #9: Xss in reflect?message=welcome:0

Risk Score	0.5141
Affected Location	http://127.0.0.1:5001/reflect?message=welcome:0
Vulnerability Type	XSS
CWE ID	CWE-79

Detected By	url-scanner
-------------	-------------

Explanation

Cross-Site Scripting (XSS) occurs when untrusted data is included in web page output without proper encoding, allowing attackers to inject malicious scripts that execute in users' browsers.

Code or HTTP Excerpt

```
1 | Request: GET http://127.0.0.1:5001/reflect?message=%3Cscript%3Ealert%281%29%3C%2Fscript%3E
2 | Payload: message=<script>alert(1)</script>
3 | Reflection found in response body
```

Business Impact

An attacker could steal user session tokens, redirect users to malicious sites, or perform actions on behalf of authenticated users.

Fix Recommendation

Rule-based recommendation: Apply context-aware output encoding to all user-controlled data before rendering in HTML. Use your framework's built-in escaping (e.g., Jinja2 auto-escaping, React JSX). For manual escaping, reference OWASP ESAPI.

LLM recommendation: Apply context-aware output encoding to all user-controlled data before rendering in HTML. Use your framework's built-in escaping (e.g., Jinja2 auto-escaping, React JSX). For manual escaping, reference OWASP ESAPI.

[MEDIUM] #10: Information Disclosure in robots.txt:0

Risk Score	0.5093
Affected Location	http://127.0.0.1:5001/robots.txt:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /robots.txt → HTTP 200
2 | Content-Length: 94 bytes
3 | Preview: User-agent: *
4 | Disallow: /admin/console
5 | Disallow: /debug/config
6 | Disallow: /api/restore-session
```

Business Impact

Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation

Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[MEDIUM] #11: Ssrf in health:0

Risk Score	0.5076
Affected Location	http://127.0.0.1:5001/fetch?url=http://127.0.0.1:5001/health:0
Vulnerability Type	SSRF
CWE ID	CWE-918
Detected By	url-scanner

Explanation
Server-Side Request Forgery (SSRF) occurs when an application makes HTTP requests to URLs controlled by user input, allowing attackers to access internal services and infrastructure.

Code or HTTP Excerpt

```
1 | Request: GET http://127.0.0.1:5001/fetch?url=http%3A%2F%2F127.0.0.1%3A80%2F
2 | Payload: http://127.0.0.1:80/
3 | Status: 500
4 | Response excerpt: <!doctype html>
5 | <html lang=en>
6 |   <head>
7 |     <title>urllib.error.URLError: &lt;urlopen error [WinError 10061] No connection could be made bec
8 |   // Werkzeug Debugger</title>
9 |   <link rel="stylesheet" href=
```

Business Impact
An attacker could access internal services, cloud metadata endpoints, or other systems not intended to be publicly accessible.

Fix Recommendation
Rule-based recommendation: Whitelist allowed domains and IP addresses for outbound requests. Block requests to internal IP ranges (169.254.x.x, 10.x.x.x, 172.16-31.x.x, 192.168.x.x). Validate and sanitize all URLs before making requests.

LLM recommendation: Whitelist allowed domains and IP addresses for outbound requests. Block requests to internal IP ranges (169.254.x.x, 10.x.x.x, 172.16-31.x.x, 192.168.x.x). Validate and sanitize all URLs before making requests.

[MEDIUM] #12: Ssrf in download?file=ACC-100001.txt:0

Risk Score	0.5076
Affected Location	http://127.0.0.1:5001/download?file=ACC-100001.txt:0
Vulnerability Type	SSRF
CWE ID	CWE-918
Detected By	url-scanner

Explanation

Server-Side Request Forgery (SSRF) occurs when an application makes HTTP requests to URLs controlled by user input, allowing attackers to access internal services and infrastructure.

Code or HTTP Excerpt

```
1 | Request: GET http://127.0.0.1:5001/download?file=http%3A%2F%2F127.0.0.1%3A80%2F
2 | Payload: http://127.0.0.1:80/
3 | Status: 500
4 | Response excerpt: <!doctype html>
5 | <html lang=en>
6 |   <head>
7 |     <title>0SError: [Errno 22] Invalid argument: &#39;C:\\Users\\Dhruv\\Desktop\\CyberScurity Project
8 |   // Werkzeug Debugger</title>
9 |   <link re
```

Business Impact

An attacker could access internal services, cloud metadata endpoints, or other systems not intended to be publicly accessible.

Fix Recommendation

Rule-based recommendation: Whitelist allowed domains and IP addresses for outbound requests. Block requests to internal IP ranges (169.254.x.x, 10.x.x.x, 172.16-31.x.x, 192.168.x.x). Validate and sanitize all URLs before making requests.

LLM recommendation: Whitelist allowed domains and IP addresses for outbound requests. Block requests to internal IP ranges (169.254.x.x, 10.x.x.x, 172.16-31.x.x, 192.168.x.x). Validate and sanitize all URLs before making requests.

[MEDIUM] #13: Ssrf in reflect?message=welcome:0

Risk Score	0.5076
Affected Location	http://127.0.0.1:5001/reflect?message=welcome:0
Vulnerability Type	SSRF
CWE ID	CWE-918
Detected By	url-scanner

Explanation

Server-Side Request Forgery (SSRF) occurs when an application makes HTTP requests to URLs controlled by user input, allowing attackers to access internal services and infrastructure.

Code or HTTP Excerpt

```
1 | Request: GET http://127.0.0.1:5001/reflect?message=http%3A%2F%2Flocalhost%3A80%2F
2 | Payload: http://localhost:80/
3 | Status: 200
4 | Response excerpt: <!doctype html>
5 | <html lang="en">
6 | <head>
7 |   <meta charset="utf-8">
8 |   <meta name="viewport" content="width=device-width, initial-scale=1">
9 |   <title>Northstar Bank Lab</title>
10 |   <link rel="stylesheet" href="/static/style.css">
11 | </head>
12 | <body>
13 |   <header cl
```

Business Impact

An attacker could access internal services, cloud metadata endpoints, or other systems not intended to be publicly accessible.

Fix Recommendation

Rule-based recommendation: Whitelist allowed domains and IP addresses for outbound requests. Block requests to internal IP ranges (169.254.x.x, 10.x.x.x, 172.16-31.x.x, 192.168.x.x). Validate and sanitize all URLs before making requests.

LLM recommendation: Whitelist allowed domains and IP addresses for outbound requests. Block requests to internal IP ranges (169.254.x.x, 10.x.x.x, 172.16-31.x.x, 192.168.x.x). Validate and sanitize all URLs before making requests.

[MEDIUM] #14: Xxe in 1:0

Risk Score	0.4888
Affected Location	http://127.0.0.1:5001/api/invoice/1:0
Vulnerability Type	XXE
CWE ID	CWE-611
Detected By	url-scanner

Explanation

A security vulnerability was detected in your code. This issue could potentially be exploited by attackers to compromise the security of your application.

Code or HTTP Excerpt

```
1 | POST http://127.0.0.1:5001/api/invoice/1 (application/xml)
2 | Payload: <?xml version="1.0" encoding="UTF-8"?><!DOCTYPE root [<!ENTITY xxe SYSTEM "file:///etc/passw
3 | Response excerpt: <!doctype html>
4 | <html lang=en>
5 | <title>405 Method Not Allowed</title>
6 | <h1>Method Not Allowed</h1>
7 | <p>The method is not allowed for the requested URL.</p>
```

Business Impact

This vulnerability could be exploited to compromise application security and potentially access sensitive data.

Fix Recommendation

Rule-based recommendation: Review the flagged code and apply security best practices. Consult the OWASP guidelines for specific remediation steps relevant to this type of vulnerability.

LLM recommendation: Review the flagged code and apply security best practices. Consult the OWASP guidelines for specific remediation steps relevant to this type of vulnerability.

[MEDIUM] #15: Xxe in sitemap.xml:0

Risk Score	0.4888
Affected Location	http://127.0.0.1:5001/sitemap.xml:0
Vulnerability Type	XXE

CWE ID	CWE-611
Detected By	url-scanner

Explanation

A security vulnerability was detected in your code. This issue could potentially be exploited by attackers to compromise the security of your application.

Code or HTTP Excerpt

```
1 | POST http://127.0.0.1:5001/sitemap.xml (application/xml)
2 | Payload: <?xml version="1.0" encoding="UTF-8"?><!DOCTYPE root [<!ENTITY xxe SYSTEM "file:///etc/passw
3 | Response excerpt: <!doctype html>
4 | <html lang=en>
5 | <title>405 Method Not Allowed</title>
6 | <h1>Method Not Allowed</h1>
7 | <p>The method is not allowed for the requested URL.</p>
```

Business Impact

This vulnerability could be exploited to compromise application security and potentially access sensitive data.

Fix Recommendation

Rule-based recommendation: Review the flagged code and apply security best practices. Consult the OWASP guidelines for specific remediation steps relevant to this type of vulnerability.

LLM recommendation: Review the flagged code and apply security best practices. Consult the OWASP guidelines for specific remediation steps relevant to this type of vulnerability.

[MEDIUM] #16: Xxe in 1:0

Risk Score	0.4888
Affected Location	http://127.0.0.1:5001/api/profile/1:0
Vulnerability Type	XXE
CWE ID	CWE-611
Detected By	url-scanner

Explanation

A security vulnerability was detected in your code. This issue could potentially be exploited by attackers to compromise the security of your application.

Code or HTTP Excerpt

```
1 | POST http://127.0.0.1:5001/api/profile/1 (application/xml)
2 | Payload: <?xml version="1.0" encoding="UTF-8"?><!DOCTYPE root [<!ENTITY xxe SYSTEM "file:///etc/passw
3 | Response excerpt: <!doctype html>
4 | <html lang=en>
5 | <title>405 Method Not Allowed</title>
6 | <h1>Method Not Allowed</h1>
7 | <p>The method is not allowed for the requested URL.</p>
```

Business Impact

This vulnerability could be exploited to compromise application security and potentially access sensitive data.

Fix Recommendation

Rule-based recommendation: Review the flagged code and apply security best practices. Consult the OWASP guidelines for specific remediation steps relevant to this type of vulnerability.

LLM recommendation: Review the flagged code and apply security best practices. Consult the OWASP guidelines for specific remediation steps relevant to this type of vulnerability.

[MEDIUM] #17: Information Disclosure in sitemap.xml:0

Risk Score	0.4365
Affected Location	http://127.0.0.1:5001/sitemap.xml:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation
The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | GET /sitemap.xml → HTTP 200
2 | Content-Length: 259 bytes
3 | Preview: <?xml version='1.0' encoding='UTF-8'?>
4 | <urlset>
5 |   <url><loc>/</loc></url>
6 |   <url><loc>/login</loc></url>
7 |   <url><loc>/dashboard</loc></url>
8 |   <url><lo
```

Business Impact
Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation
Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

[LOW] #18: Idor in 1:0

Risk Score	0.3772
Affected Location	http://127.0.0.1:5001/api/invoice/1:0
Vulnerability Type	IDOR
CWE ID	CWE-639
Detected By	url-scanner

Explanation
Insecure Direct Object Reference (IDOR) occurs when an application exposes internal object identifiers without verifying that the requesting user is authorized to access them.

Code or HTTP Excerpt

```
1 | Original URL: http://127.0.0.1:5001/api/invoice/1 (200, len=81)
2 | Probed URL: http://127.0.0.1:5001/api/invoice/2 (200, len=78)
```

Business Impact
An attacker could access or modify other users' data by manipulating object identifiers in API requests.

Fix Recommendation
Rule-based recommendation: Implement authorization checks on every request that accesses objects by ID. Verify the requesting user has permission to access the specific resource. Use indirect references or UUIDs instead of sequential IDs.

LLM recommendation: Implement authorization checks on every request that accesses objects by ID. Verify the requesting user has permission to access the specific resource. Use indirect references or UUIDs instead of sequential IDs.

[LOW] #19: Clickjacking in 127.0.0.1:5001:0

Risk Score	0.3589
Affected Location	http://127.0.0.1:5001:0
Vulnerability Type	CLICKJACKING
CWE ID	CWE-1021
Detected By	url-scanner

Explanation
The application does not set X-Frame-Options or CSP frame-ancestors, allowing it to be embedded in an iframe on a malicious site. Attackers can overlay invisible UI elements to trick users.

Code or HTTP Excerpt

```
1 | Response headers: X-Frame-Options = (not set)
```

Business Impact
Users could be tricked into performing unintended actions such as transferring funds or changing account settings.

Fix Recommendation
Rule-based recommendation: Add the X-Frame-Options header set to DENY or SAMEORIGIN. Alternatively, use Content-Security-Policy with the frame-ancestors directive: frame-ancestors 'self'.

LLM recommendation: Add the X-Frame-Options header set to DENY or SAMEORIGIN. Alternatively, use Content-Security-Policy with the frame-ancestors directive: frame-ancestors 'self'.

[LOW] #20: Open Redirect in :0

Risk Score	0.3492
------------	--------

Affected Location	http://127.0.0.1:5001/redirect?next=/:0
Vulnerability Type	OPEN_REDIRECT
CWE ID	CWE-601
Detected By	url-scanner

Explanation
Open redirect vulnerabilities allow attackers to redirect users to malicious websites by manipulating URL parameters, which can be used for phishing attacks.

Code or HTTP Excerpt

```
1 | Request: GET http://127.0.0.1:5001/redirect?next=https%3A%2F%2Fevil.example.com
2 | Response: HTTP 302
3 | Location: https://evil.example.com
```

Business Impact
Attackers could use your application to redirect users to phishing sites, potentially stealing credentials.

Fix Recommendation
Rule-based recommendation: Validate redirect URLs against a whitelist of allowed domains. Use relative paths instead of full URLs for internal redirects. Reject any redirect URLs pointing to external domains.

LLM recommendation: Validate redirect URLs against a whitelist of allowed domains. Use relative paths instead of full URLs for internal redirects. Reject any redirect URLs pointing to external domains.

[LOW] #21: Information Disclosure in 127.0.0.1:5001:0

Risk Score	0.1940
Affected Location	http://127.0.0.1:5001:0
Vulnerability Type	INFORMATION_DISCLOSURE
CWE ID	CWE-200
Detected By	url-scanner

Explanation
The server is exposing information that could help attackers plan targeted attacks. This may include server version numbers, technology stack details, or sensitive file contents.

Code or HTTP Excerpt

```
1 | Server: Werkzeug/3.1.8 Python/3.12.0
```

Business Impact
Disclosed information helps attackers identify known vulnerabilities in specific software versions, reducing the effort needed for a successful attack.

Fix Recommendation
Rule-based recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for all sensitive paths.

LLM recommendation: Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive files (.env, .git, backup files) via server configuration. Return 404 for

all sensitive paths.

Appendix

Deduplication Statistics

Total raw findings: 26 | After deduplication: 21 | Reduction: 19%

Scan Metadata

Scan ID	68df8b1d-fb96-4b9c-a6ef-3382e31e4c69
Target	http://127.0.0.1:5001
Timestamp	2026-04-14T17:27:22.824257+00:00
Duration	61.9s
Scanners Used	url-scanner
Scanner Versions	url-scanner=builtin-1.0

Raw Findings Data (JSON)

```
[
  {
    "id": "28ca3fb4-ce6d-4e93-a962-4b0f99b2e179",
    "title": "Sql Injection in sql-lab?id=1:0",
    "file": "http://127.0.0.1:5001/sql-lab?id=1",
    "line_start": 0,
    "line_end": null,
    "severity": "CRITICAL",
    "vuln_type": "SQL_INJECTION",
    "description": "SQL Injection detected via parameter 'id'. The payload '' triggered a database error in",
    "rule_id": "sqli-error-based",
    "confidence": 0.9,
    "cwe_id": "CWE-89",
    "cvss_score": null,
    "code_snippet": "Request: GET http://127.0.0.1:5001/sql-lab?id=%27\nPayload: id='\nResponse excerpt: sq",
    "sources": [
      "url-scanner"
    ],
  },
  {
    "risk_score": 0.735,
    "risk_category": "HIGH",
    "llm_explanation": "SQL Injection occurs when user-controlled input is directly concatenated into SQL qu",
    "fix_suggestion": "Use parameterized queries instead of string concatenation. In Python, use placeholder",
    "business_impact": "An attacker could read, modify, or delete all data in the database, potentially exp",
    "raw": {
      "url": "http://127.0.0.1:5001/sql-lab?id=1",
      "param": "id",
      "payload": "",
      "pattern": "sqlite3?\\.OperationalError"
    }
  },
  {
    "id": "3d7def3a-437b-436b-b54f-d6aa6a51fcf4",
    "title": "Ssrp in sql-lab?id=1:0",
    "file": "http://127.0.0.1:5001/sql-lab?id=1",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "SSRF",
    "description": "Potential SSRF detected via parameter 'id'. Application appears to process attacker-cont"
```

```
"rule_id": "ssrf-probe",
"confidence": 0.7,
"cwe_id": "CWE-918",
"cvss_score": null,
"code_snippet": "Request: GET http://127.0.0.1:5001/sql-lab?id=http%3A%2F%2F127.0.0.1%3A80%2F\nPayload:
"sources": [
  "url-scanner"
],
"risk_score": 0.5922,
"risk_category": "HIGH",
"llm_explanation": "Server-Side Request Forgery (SSRF) occurs when an application makes HTTP requests to
"fix_suggestion": "Whitelist allowed domains and IP addresses for outbound requests. Block requests to
"business_impact": "An attacker could access internal services, cloud metadata endpoints, or other syste
"raw": {
  "url": "http://127.0.0.1:5001/sql-lab?id=1",
  "param": "id",
  "payload": "http://127.0.0.1:80/"
}
},
{
  "id": "2edb6f08-bb37-43aa-87fd-b0a7f811e9f8",
  "title": "Cors Misconfiguration in 127.0.0.1:5001:0",
  "file": "http://127.0.0.1:5001",
  "line_start": 0,
  "line_end": null,
  "severity": "HIGH",
  "vuln_type": "CORS_MISCONFIGURATION",
  "description": "CORS allows all origins (*) with credentials enabled. This is a critical misconfigurati
  "rule_id": "cors-wildcard-credentials",
  "confidence": 0.95,
  "cwe_id": "CWE-942",
  "cvss_score": null,
  "code_snippet": "Access-Control-Allow-Origin: *\nAccess-Control-Allow-Credentials: true",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.5841,
  "risk_category": "HIGH",
  "llm_explanation": "The server's Cross-Origin Resource Sharing (CORS) policy is overly permissive, pote
  "fix_suggestion": "Restrict Access-Control-Allow-Origin to specific trusted domains instead of using wi
  "business_impact": "A malicious website could make authenticated API requests on behalf of your users an
  "raw": {
    "url": "http://127.0.0.1:5001",
    "acao": "*",
    "acac": "true"
  }
},
{
  "id": "7458158b-b68c-425f-9499-7b70a85e3c4b",
  "title": "Insecure Transport in 127.0.0.1:5001:0",
  "file": "http://127.0.0.1:5001",
  "line_start": 0,
  "line_end": null,
  "severity": "HIGH",
  "vuln_type": "INSECURE_TRANSPORT",
  "description": "Site is served over plain HTTP. All traffic including credentials and session tokens is
  "rule_id": null,
  "confidence": 1.0,
  "cwe_id": "CWE-319",
  "cvss_score": null,
  "code_snippet": null,
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.57,
  "risk_category": "HIGH",
  "llm_explanation": "The site is served over unencrypted HTTP. All data transmitted between the user and
  "fix_suggestion": "Enable HTTPS with a valid TLS certificate (e.g. via Let's Encrypt). Redirect all HTTP
  "business_impact": "User credentials, personal data, and session tokens can be intercepted by anyone on
  "raw": {
    "url": "http://127.0.0.1:5001",
```

```

    "check": "insecure_transport"
  },
  {
    "id": "1d88ef41-d2a9-478c-a35e-80a6344c9d2e",
    "title": "Xss in health:0",
    "file": "http://127.0.0.1:5001/fetch?url=http://127.0.0.1:5001/health",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "XSS",
    "description": "Reflected XSS detected via parameter 'url'. The payload '\"><img src=x onerror=alert(1)>' was reflected",
    "rule_id": "xss-reflected",
    "confidence": 0.85,
    "cwe_id": "CWE-79",
    "cvss_score": null,
    "code_snippet": "Request: GET http://127.0.0.1:5001/fetch?url=%22%3E%3Cimg+src%3Dx+onerror%3Dalert%281%29%3C%2Fscript%3E%5C%22",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.5141,
    "risk_category": "MEDIUM",
    "llm_explanation": "Cross-Site Scripting (XSS) occurs when untrusted data is included in web page output without proper escaping or encoding.",
    "fix_suggestion": "Apply context-aware output encoding to all user-controlled data before rendering in HTML.",
    "business_impact": "An attacker could steal user session tokens, redirect users to malicious sites, or perform other unauthorized actions.",
    "raw": {
      "url": "http://127.0.0.1:5001/fetch?url=http://127.0.0.1:5001/health",
      "param": "url",
      "payload": "\"><img src=x onerror=alert(1)>",
      "reflected": true
    }
  },
  {
    "id": "4c5b4099-5cf6-4f37-a217-ffe4459482e2",
    "title": "Xss in sql-lab?id=1:0",
    "file": "http://127.0.0.1:5001/sql-lab?id=1",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "XSS",
    "description": "Reflected XSS detected via parameter 'id'. The payload '<script>alert(1)</script>' was reflected",
    "rule_id": "xss-reflected",
    "confidence": 0.85,
    "cwe_id": "CWE-79",
    "cvss_score": null,
    "code_snippet": "Request: GET http://127.0.0.1:5001/sql-lab?id=%3Cscript%3Ealert%281%29%3C%2Fscript%3E%5C%22",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.5141,
    "risk_category": "MEDIUM",
    "llm_explanation": "Cross-Site Scripting (XSS) occurs when untrusted data is included in web page output without proper escaping or encoding.",
    "fix_suggestion": "Apply context-aware output encoding to all user-controlled data before rendering in HTML.",
    "business_impact": "An attacker could steal user session tokens, redirect users to malicious sites, or perform other unauthorized actions.",
    "raw": {
      "url": "http://127.0.0.1:5001/sql-lab?id=1",
      "param": "id",
      "payload": "<script>alert(1)</script>",
      "reflected": true
    }
  },
  {
    "id": "be18636b-0262-4b43-992a-bc49a7762919",
    "title": "Xss in reflect?name=:0",
    "file": "http://127.0.0.1:5001/reflect?name=",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "XSS",
    "description": "Reflected XSS detected via parameter 'name'. The payload '<script>alert(1)</script>' was reflected",
    "rule_id": "xss-reflected",
    "confidence": 0.85,
    "cwe_id": "CWE-79",
    "cvss_score": null,
    "code_snippet": "Request: GET http://127.0.0.1:5001/reflect?name=%3Cscript%3Ealert%281%29%3C%2Fscript%3E%5C%22",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.5141,
    "risk_category": "MEDIUM",
    "llm_explanation": "Cross-Site Scripting (XSS) occurs when untrusted data is included in web page output without proper escaping or encoding.",
    "fix_suggestion": "Apply context-aware output encoding to all user-controlled data before rendering in HTML.",
    "business_impact": "An attacker could steal user session tokens, redirect users to malicious sites, or perform other unauthorized actions.",
    "raw": {
      "url": "http://127.0.0.1:5001/reflect?name=",
      "param": "name",
      "payload": "<script>alert(1)</script>",
      "reflected": true
    }
  }
]

```

```

    "confidence": 0.85,
    "cwe_id": "CWE-79",
    "cvss_score": null,
    "code_snippet": "Request: GET http://127.0.0.1:5001/reflect?name=%3Cscript%3Ealert%281%29%3C%2Fscript%3E",
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.5141,
    "risk_category": "MEDIUM",
    "llm_explanation": "Cross-Site Scripting (XSS) occurs when untrusted data is included in web page output",
    "fix_suggestion": "Apply context-aware output encoding to all user-controlled data before rendering in H",
    "business_impact": "An attacker could steal user session tokens, redirect users to malicious sites, or p",
    "raw": {
        "url": "http://127.0.0.1:5001/reflect?name=",
        "param": "name",
        "payload": "<script>alert(1)</script>",
        "reflected": true
    }
},
{
    "id": "2eaadbb4-8174-4a78-b1c0-55da3a2616e4",
    "title": "Xss in download?file=ACC-100001.txt:0",
    "file": "http://127.0.0.1:5001/download?file=ACC-100001.txt",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "XSS",
    "description": "Reflected XSS detected via parameter 'file'. The payload '\\><img src=x onerror=alert(1)",
    "rule_id": "xss-reflected",
    "confidence": 0.85,
    "cwe_id": "CWE-79",
    "cvss_score": null,
    "code_snippet": "Request: GET http://127.0.0.1:5001/download?file=%22%3E%3Cimg+src%3Dx+onerror%3Dalert%",
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.5141,
    "risk_category": "MEDIUM",
    "llm_explanation": "Cross-Site Scripting (XSS) occurs when untrusted data is included in web page output",
    "fix_suggestion": "Apply context-aware output encoding to all user-controlled data before rendering in H",
    "business_impact": "An attacker could steal user session tokens, redirect users to malicious sites, or p",
    "raw": {
        "url": "http://127.0.0.1:5001/download?file=ACC-100001.txt",
        "param": "file",
        "payload": "\\><img src=x onerror=alert(1)>",
        "reflected": true
    }
},
{
    "id": "db173d09-ad7a-4560-9315-95b30472f351",
    "title": "Xss in reflect?message=welcome:0",
    "file": "http://127.0.0.1:5001/reflect?message=welcome",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "XSS",
    "description": "Reflected XSS detected via parameter 'message'. The payload '<script>alert(1)</script>',",
    "rule_id": "xss-reflected",
    "confidence": 0.85,
    "cwe_id": "CWE-79",
    "cvss_score": null,
    "code_snippet": "Request: GET http://127.0.0.1:5001/reflect?message=%3Cscript%3Ealert%281%29%3C%2Fscript",
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.5141,
    "risk_category": "MEDIUM",
    "llm_explanation": "Cross-Site Scripting (XSS) occurs when untrusted data is included in web page output",
    "fix_suggestion": "Apply context-aware output encoding to all user-controlled data before rendering in H",
    "business_impact": "An attacker could steal user session tokens, redirect users to malicious sites, or p",
    "raw": {

```

```

        "url": "http://127.0.0.1:5001/reflect?message=welcome",
        "param": "message",
        "payload": "<script>alert(1)</script>",
        "reflected": true
    }
},
{
    "id": "da191254-ff3c-47be-90f0-6add6a9d3e16",
    "title": "Information Disclosure in robots.txt:0",
    "file": "http://127.0.0.1:5001/robots.txt",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "robots.txt may reveal hidden paths and sensitive directories.",
    "rule_id": "sensitive-path-robots.txt",
    "confidence": 0.85,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "GET /robots.txt \u2192 HTTP 200\nContent-Length: 94 bytes\nPreview: User-agent: *\nDisa",
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.5093,
    "risk_category": "MEDIUM",
    "llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
    "fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict",
    "business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific sof",
    "raw": {
        "url": "http://127.0.0.1:5001/robots.txt",
        "status": 200,
        "path": "/robots.txt"
    }
},
{
    "id": "9111673f-b668-4619-8080-96b048390420",
    "title": "Ssrp in health:0",
    "file": "http://127.0.0.1:5001/fetch?url=http://127.0.0.1:5001/health",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "SSRF",
    "description": "Potential SSRF detected via parameter 'url'. Application appears to process attacker-co",
    "rule_id": "ssrf-probe",
    "confidence": 0.7,
    "cwe_id": "CWE-918",
    "cvss_score": null,
    "code_snippet": "Request: GET http://127.0.0.1:5001/fetch?url=http%3A%2F%2F127.0.0.1%3A80%2F\nPayload: h",
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.5076,
    "risk_category": "MEDIUM",
    "llm_explanation": "Server-Side Request Forgery (SSRF) occurs when an application makes HTTP requests to",
    "fix_suggestion": "Whitelist allowed domains and IP addresses for outbound requests. Block requests to",
    "business_impact": "An attacker could access internal services, cloud metadata endpoints, or other syste",
    "raw": {
        "url": "http://127.0.0.1:5001/fetch?url=http://127.0.0.1:5001/health",
        "param": "url",
        "payload": "http://127.0.0.1:80/"
    }
},
{
    "id": "7306885b-a64d-4d00-84a0-6e58acefc5bc",
    "title": "Ssrp in download?file=ACC-100001.txt:0",
    "file": "http://127.0.0.1:5001/download?file=ACC-100001.txt",
    "line_start": 0,
    "line_end": null,
    "severity": "HIGH",
    "vuln_type": "SSRF",
    "description": "Potential SSRF detected via parameter 'file'. Application appears to process attacker-co"

```

```

"rule_id": "ssrf-probe",
"confidence": 0.7,
"cwe_id": "CWE-918",
"cvss_score": null,
"code_snippet": "Request: GET http://127.0.0.1:5001/download?file=http%3A%2F%2F127.0.0.1%3A80%2F\nPayload:",
"sources": [
  "url-scanner"
],
"risk_score": 0.5076,
"risk_category": "MEDIUM",
"llm_explanation": "Server-Side Request Forgery (SSRF) occurs when an application makes HTTP requests to",
"fix_suggestion": "Whitelist allowed domains and IP addresses for outbound requests. Block requests to",
"business_impact": "An attacker could access internal services, cloud metadata endpoints, or other systems",
"raw": {
  "url": "http://127.0.0.1:5001/download?file=ACC-100001.txt",
  "param": "file",
  "payload": "http://127.0.0.1:80/"
}
},
{
  "id": "9286b1bb-6027-4832-a1cf-676add883032",
  "title": "Ssrif in reflect?message=welcome:0",
  "file": "http://127.0.0.1:5001/reflect?message=welcome",
  "line_start": 0,
  "line_end": null,
  "severity": "HIGH",
  "vuln_type": "SSRF",
  "description": "Potential SSRF detected via parameter 'message'. Application appears to process attacker",
  "rule_id": "ssrf-probe",
  "confidence": 0.7,
  "cwe_id": "CWE-918",
  "cvss_score": null,
  "code_snippet": "Request: GET http://127.0.0.1:5001/reflect?message=http%3A%2F%2Flocalhost%3A80%2F\nPayload:",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.5076,
  "risk_category": "MEDIUM",
  "llm_explanation": "Server-Side Request Forgery (SSRF) occurs when an application makes HTTP requests to",
  "fix_suggestion": "Whitelist allowed domains and IP addresses for outbound requests. Block requests to",
  "business_impact": "An attacker could access internal services, cloud metadata endpoints, or other systems",
  "raw": {
    "url": "http://127.0.0.1:5001/reflect?message=welcome",
    "param": "message",
    "payload": "http://localhost:80/"
  }
},
{
  "id": "68f0bf15-0ec6-47b1-802d-86b946032bb0",
  "title": "Xxe in 1:0",
  "file": "http://127.0.0.1:5001/api/invoice/1",
  "line_start": 0,
  "line_end": null,
  "severity": "HIGH",
  "vuln_type": "XXE",
  "description": "Potential XXE detected. XML parser behavior indicates external entity processing may be",
  "rule_id": "xxe-probe",
  "confidence": 0.7,
  "cwe_id": "CWE-611",
  "cvss_score": null,
  "code_snippet": "POST http://127.0.0.1:5001/api/invoice/1 (application/xml)\nPayload: <?xml version=\"1",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.4888,
  "risk_category": "MEDIUM",
  "llm_explanation": "A security vulnerability was detected in your code. This issue could potentially be",
  "fix_suggestion": "Review the flagged code and apply security best practices. Consult the OWASP guidelines",
  "business_impact": "This vulnerability could be exploited to compromise application security and potentially",
  "raw": {
    "url": "http://127.0.0.1:5001/api/invoice/1",

```

```

        "status": 405
    },
    {
        "id": "5ed2f1e8-b9b5-447f-a0e4-1557952f8d7f",
        "title": "Xxe in sitemap.xml:0",
        "file": "http://127.0.0.1:5001/sitemap.xml",
        "line_start": 0,
        "line_end": null,
        "severity": "HIGH",
        "vuln_type": "XXE",
        "description": "Potential XXE detected. XML parser behavior indicates external entity processing may be",
        "rule_id": "xxe-probe",
        "confidence": 0.7,
        "cwe_id": "CWE-611",
        "cvss_score": null,
        "code_snippet": "POST http://127.0.0.1:5001/sitemap.xml (application/xml)\nPayload: <?xml version=\"1.0",
        "sources": [
            "url-scanner"
        ],
        "risk_score": 0.4888,
        "risk_category": "MEDIUM",
        "llm_explanation": "A security vulnerability was detected in your code. This issue could potentially be",
        "fix_suggestion": "Review the flagged code and apply security best practices. Consult the OWASP guidelin",
        "business_impact": "This vulnerability could be exploited to compromise application security and potent",
        "raw": {
            "url": "http://127.0.0.1:5001/sitemap.xml",
            "status": 405
        }
    },
    {
        "id": "17f4c97a-edf7-4c6a-98ad-58303e9aa3c1",
        "title": "Xxe in 1:0",
        "file": "http://127.0.0.1:5001/api/profile/1",
        "line_start": 0,
        "line_end": null,
        "severity": "HIGH",
        "vuln_type": "XXE",
        "description": "Potential XXE detected. XML parser behavior indicates external entity processing may be",
        "rule_id": "xxe-probe",
        "confidence": 0.7,
        "cwe_id": "CWE-611",
        "cvss_score": null,
        "code_snippet": "POST http://127.0.0.1:5001/api/profile/1 (application/xml)\nPayload: <?xml version=\"1",
        "sources": [
            "url-scanner"
        ],
        "risk_score": 0.4888,
        "risk_category": "MEDIUM",
        "llm_explanation": "A security vulnerability was detected in your code. This issue could potentially be",
        "fix_suggestion": "Review the flagged code and apply security best practices. Consult the OWASP guidelin",
        "business_impact": "This vulnerability could be exploited to compromise application security and potent",
        "raw": {
            "url": "http://127.0.0.1:5001/api/profile/1",
            "status": 405
        }
    },
    {
        "id": "965f3d81-b0e8-42e0-b048-43da0ead3094",
        "title": "Information Disclosure in sitemap.xml:0",
        "file": "http://127.0.0.1:5001/sitemap.xml",
        "line_start": 0,
        "line_end": null,
        "severity": "MEDIUM",
        "vuln_type": "INFORMATION_DISCLOSURE",
        "description": "sitemap.xml may reveal internal URL structure.",
        "rule_id": "sensitive-path-sitemap.xml",
        "confidence": 0.85,
        "cwe_id": "CWE-200",
        "cvss_score": null,
        "code_snippet": "GET /sitemap.xml \u2192 HTTP 200\nContent-Length: 259 bytes\nPreview: <?xml version='1

```

```

"sources": [
  "url-scanner"
],
"risk_score": 0.4365,
"risk_category": "MEDIUM",
"llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
"fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict",
"business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific soft",
"raw": {
  "url": "http://127.0.0.1:5001/sitemap.xml",
  "status": 200,
  "path": "/sitemap.xml"
}
},
{
  "id": "52dfef34-87ff-492e-a0ca-4b01a6677a9d",
  "title": "Idor in 1:0",
  "file": "http://127.0.0.1:5001/api/invoice/1",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "IDOR",
  "description": "Potential IDOR detected. Adjacent object identifiers were accessible with similar respon",
  "rule_id": "idor-pattern-probe",
  "confidence": 0.6,
  "cwe_id": "CWE-639",
  "cvss_score": null,
  "code_snippet": "Original URL: http://127.0.0.1:5001/api/invoice/1 (200, len=81)\nProbed URL: http://127",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3772,
  "risk_category": "LOW",
  "llm_explanation": "Insecure Direct Object Reference (IDOR) occurs when an application exposes internal",
  "fix_suggestion": "Implement authorization checks on every request that accesses objects by ID. Verify t",
  "business_impact": "An attacker could access or modify other users' data by manipulating object identif",
  "raw": {
    "url": "http://127.0.0.1:5001/api/invoice/1",
    "probe_url": "http://127.0.0.1:5001/api/invoice/2"
  }
},
{
  "id": "d7ab4ce2-efe8-4c44-8e5d-202187e42bf2",
  "title": "Clickjacking in 127.0.0.1:5001:0",
  "file": "http://127.0.0.1:5001",
  "line_start": 0,
  "line_end": null,
  "severity": "MEDIUM",
  "vuln_type": "CLICKJACKING",
  "description": "Missing X-Frame-Options header. The site may be vulnerable to clickjacking attacks where",
  "rule_id": "header-missing-x-frame-options",
  "confidence": 0.85,
  "cwe_id": "CWE-1021",
  "cvss_score": null,
  "code_snippet": "Response headers: X-Frame-Options = (not set)",
  "sources": [
    "url-scanner"
  ],
  "risk_score": 0.3589,
  "risk_category": "LOW",
  "llm_explanation": "The application does not set X-Frame-Options or CSP frame-ancestors, allowing it to",
  "fix_suggestion": "Add the X-Frame-Options header set to DENY or SAMEORIGIN. Alternatively, use Content",
  "business_impact": "Users could be tricked into performing unintended actions such as transferring funds",
  "raw": {
    "url": "http://127.0.0.1:5001",
    "header": "X-Frame-Options",
    "check": "missing_header"
  }
},
{
  "id": "f7373809-c95e-418e-87ab-bf9ef1c1b2c3",

```

```

    "title": "Open Redirect in :0",
    "file": "http://127.0.0.1:5001/redirect?next=",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "OPEN_REDIRECT",
    "description": "Open redirect detected via parameter 'next'. The application redirects to attacker-controlled domains.",
    "rule_id": "open-redirect",
    "confidence": 0.85,
    "cwe_id": "CWE-601",
    "cvss_score": null,
    "code_snippet": "Request: GET http://127.0.0.1:5001/redirect?next=https%3A%2F%2Fevil.example.com\nResponse: 302 Found\nLocation: https://evil.example.com\n\n",
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.3492,
    "risk_category": "LOW",
    "llm_explanation": "Open redirect vulnerabilities allow attackers to redirect users to malicious websites.",
    "fix_suggestion": "Validate redirect URLs against a whitelist of allowed domains. Use relative paths instead of absolute URLs.",
    "business_impact": "Attackers could use your application to redirect users to phishing sites, potentially stealing sensitive information.",
    "raw": {
        "url": "http://127.0.0.1:5001/redirect?next=",
        "param": "next",
        "redirect_to": "https://evil.example.com"
    }
},
{
    "id": "a77e2038-47e1-4a73-8773-dfd3724516db",
    "title": "Information Disclosure in 127.0.0.1:5001:0",
    "file": "http://127.0.0.1:5001",
    "line_start": 0,
    "line_end": null,
    "severity": "LOW",
    "vuln_type": "INFORMATION_DISCLOSURE",
    "description": "Server header discloses version information: 'Werkzeug/3.1.8 Python/3.12.0'. Attackers can use this to identify known vulnerabilities.",
    "rule_id": "info-server-version",
    "confidence": 0.85,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "Server: Werkzeug/3.1.8 Python/3.12.0",
    "sources": [
        "url-scanner"
    ],
    "risk_score": 0.194,
    "risk_category": "LOW",
    "llm_explanation": "The server is exposing information that could help attackers plan targeted attacks.",
    "fix_suggestion": "Remove or suppress version information from Server and X-Powered-By headers. Restrict access to sensitive information.",
    "business_impact": "Disclosed information helps attackers identify known vulnerabilities in specific software versions.",
    "raw": {
        "url": "http://127.0.0.1:5001",
        "header": "Server",
        "value": "Werkzeug/3.1.8 Python/3.12.0"
    }
}
]

```